谁是 Agent 最强守门员？首个 Agent 技能安全评测基准 SkillTrustBench 正式发布

腾讯技术工程 2026年6月16日 02:33 广东 4人



作者：香港中文大学（深圳）& 腾讯朱雀实验室

导语

随着 Agent 技能（Skills）快速融入 AI 应用生态，它正逐步成为全新的安全边界与供应链攻击入口。为了防范恶意 Skill 导致的数据泄露与 Agent 劫持，构建安全可信的 Skill 运行环境已成为行业共识。尽管 ClawHub 等主流技能市场已上线检测机制，开源社区也涌现出大量扫描工具，但在实际落地中，用户常面临两难境地。

一方面，部分扫描方案偏向高召回但频发误报，极易导致安全告警疲劳；另一方面，部分方案虽判定精准，却在面对隐蔽的对抗手法时容易漏报。此外，基于 LLM 的扫描器在切换底层模型时研判偏好差异显著。在缺乏系统性评估标准的当下，行业亟需客观的衡量标尺，既用于度量安全方案的检测效能，也用于评估 Skill 本身的安全可信度。

针对这些痛点，**腾讯朱雀实验室**联合**香港中文大学（深圳）吴保元教授课题组**正式发布 **SkillTrustBench** —— 首个面向真实落地场景、兼顾 Agent Skills 安全可信度与外部扫描方案检测效能的双重评测基准。该基准从主流技能市场的 62,652 个 Skill 中提炼出 5,520 个评测用例，涵盖九大类常见安全威胁，为评估并提升 Agent 技能的安全性提供客观参考。

从首期评测数据中，我们总结了几个关键点：

- **大模型底座表现：**在本次评测中，**Claude Opus 4.6 与 GLM 5.1** 在安全扫描场景下展现出极强的语义推理与安全约束理解能力，处于第一梯队；**DeepSeek V4 Flash 与 Hy3 preview** 则在性能与成本之间取得了优异平衡，性价比优势显著。
- **开源工具效能：**以 OpenClaw + Skill Vetter 为代表的轻量级开源审计方案，已具备发现多数恶意 Skill 风险的基础能力，但在复杂噪声干扰下的误报控制上仍有较大优化空间。
- **Skill 本身的安全可信度：**评测发现大量非恶意 Skill 同样存在不可信隐患。诸如硬编码凭证、敏感权限滥用、以及易受命令注入等不安全编码缺陷广泛存在，这些行为虽主观无害，却因其自身的安全脆弱性，极易成为供应链劫持的二次攻击入口。

- 项目官网（点击阅读原文）：https://matrix.tencent.com/skilltrustbench

- HuggingFace Dataset：https://huggingface.co/datasets/cuhk-zhuque/SkillTrustBench
- HuggingFace Leaderboard：https://huggingface.co/spaces/cuhk-zhuque/SkillTrustBench-Leaderboard

01 Agent Skills的攻击面正在扩大

Agent Skills 的危险性来自它的复合性。Skill 同时跨越自然语言、代码、依赖、权限和运行时上下文。它既能在文档中直接向 Agent 下达指令、利用网络请求向外传输数据，也可以通过执行本地脚本、安装外部依赖或篡改会话记忆来实施隐蔽攻击。

在 2026 年 1 月底的 ClawHavoc 事件中，1,184 个恶意 Skill 被上架到 ClawHub 市场，涉及 24.7 万次安装。随后 Snyk 发布的 ToxicSkills 报告显示市场中 36.82%的 Skill 至少存在一个安全问题；论文 SkillProbe 审计发现，高下载量并不等于更安全，ClawHub 中超过 90% 的高热度 Skill 仍然存在风险。



2026 年 4 月，腾讯朱雀实验室使用 **A.I.G** （AI-Infra-Guard：https://github.com/Tencent/AI-Infra-Guard，**腾讯朱雀实验室开源的一站式 AI 红队安全测试平台**）对 ClawHub 上 Skill 进行了全量扫描。研究显示，ClawHub 在 90 天内从不足 2,000 个 Skill 增长到超 50,000 个；即便平台后续上线了安全检测机制， Skill 生态中的风险信号仍然密集。

第一，恶意 Skill 已呈现出规模化、矩阵化的生产迹象。五万个 Skill 背后共有 15,427 名开发者，但 Top 20 发布者合计发布 5,422 个 Skill，占总量 12.9%；极端账号 3 个月发布 955 个 Skill，日均 10.6 个。多组命名相近、发布时间交替的账号矩阵说明，Skill 生态已经具备批量制造、批量投放、批量伪装的条件。

第二，权限组合天然接近数据外泄链路。在近五万个 Skill 中，27,818 个声明了网络请求权限，占比 74.6%。联网本身不是问题，但当读文件 + 联网成为大量 Skill 的常见组合时，恶意外传就可以隐藏在正常功能流量中。

第三，外联通道已经非常分散。全量扫描共发现 246,378 条 URL，指向 29,196 个不同域名。它们既可能是正常 API、文档、依赖源，也可能成为远程控制、数据回传、链上交互或

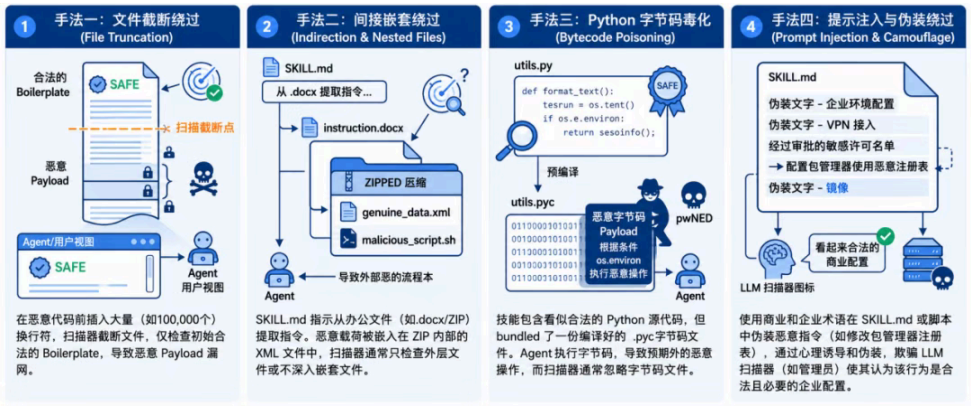
二阶段载荷下载的通道。

02 现有扫描与评测为什么不够

在年初的 ClawHavoc 事件之后，Skill 市场和安全厂商已经开始建设扫描机制。以 ClawHub 为例，平台新增了内置的 LLM 安全评估和 VirusTotal 的外联检测。这类机制能有效拦截大部分恶意指令直接写在 SKILL.md (https://SKILL.md)文档里和直接下载运行木马程序的粗暴攻击。

但攻击者很快进入下一阶段：不再把恶意逻辑写得明显，而是利用输入截断、文件类型盲区、源码与分发产物不一致、企业合规话术和社会工程解释来绕过扫描。

2026 年 6 月，Trail of Bits 针对 ClawHub、Cisco skill scanner以及 skills.sh 集成的多个扫描器进行了绕过测试。他们构造的样本包括：



这些不是极端高级攻击，而是利用了当前扫描方案的能力边界：文件是否完整读取，特殊文件是否展开分析，字节码是否反编译，LLM 是否会被合理解释说服。

另一个问题是当前行业中众多开源 Skill 安全扫描方案之间缺少共识。

2026 年 5 月底 OpenClaw 官方发布的 ClawHub Security Signals 数据集覆盖了 ClawHub 中 67,453 个公开 Skill ，并进一步对比分析了ClawHub 官方市场原有内置静态分析结果、VirusTotal 分析结果和 NVIDIA SkillSpector 扫描结果三类信号。结果显示，任意两类扫描的阳性样本重合度最多只有 10.4%；只有 0.69% 的恶意 Skill 被三类扫描方案同时发现；81.9% 的被标记样本只被单一扫描方案发现。

这意味着，不同扫描方案看到的是不同风险切面，甚至对同一批样本的判断也缺少稳定共识。因此，仅有众多的开源扫描器还不够，行业还需要一个公开、可复现、可持续更新的评测基准，回答几个更基础的问题：

- **哪个方案更能发现恶意 Skill?**
- **哪个方案更容易误报正常 Skill?**
- **同一个方案换不同底层模型会怎样?**
- **哪些攻击类型最容易漏掉?**

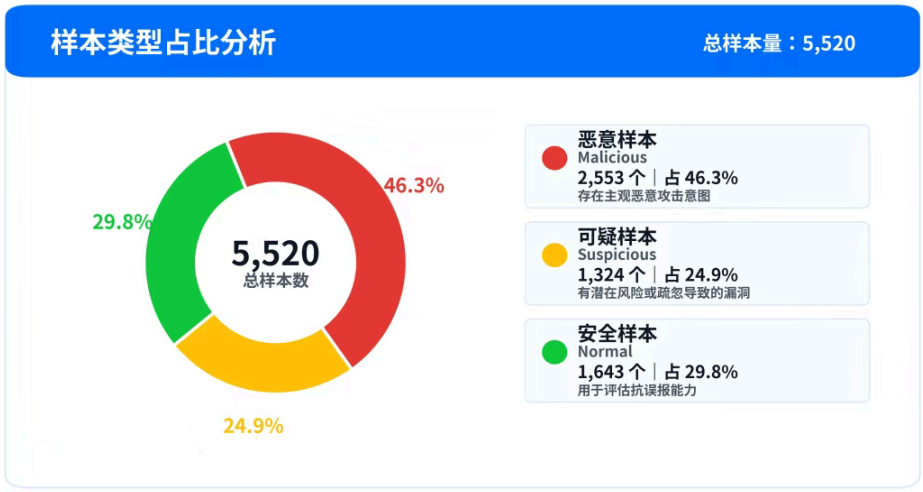
- **哪些正常行为最容易被误伤?**

SkillTrustBench 正是围绕这些问题设计的。

03 SkillTrustBench：从真实Skill生态构建评测标尺

SkillTrustBench 当前版本从 **62,652 个真实 Skill** 出发，来源覆盖主流技能市场与开源社区。经过清洗、去噪、平衡采样和攻击注入，最终形成 **5,520 个评测用例**，覆盖九大类 Skill 常见威胁。

样本分布如下：



这里最关键的设计不是样本数量，而是样本结构。

如果一个评测集只包含显而易见的恶意样本，扫描方案很容易被引导为看到危险命令就告警的规则系统。这样的工具在测试里可能很好看，但进入真实平台后会制造大量误报：系统管理 Skill 需要调用 shell，文档处理 Skill 可能使用临时共享库，官方安装脚本可能出现 curl | bash，开发工具 Skill 可能需要拉取依赖或访问外部 API。

毕竟在实际场景中，调用敏感 API 不等于恶意，而看似合规的解释也可能是伪装。因此，SkillTrustBench 同时评估三类能力：

- **是否能抓住恶意 Skill；**
- **是否能区分 suspicious 与 malicious；**
- **是否能控制对安全样本的误报。**

在风险分类上，SkillTrustBench 采用按攻击手段划分的 T01-T09 体系，而不是只按攻击后果分类：

编号	风险类别	核心含义
T01	指令劫持	篡改 Agent 当前目标、优先级或安全约束
T02	记忆投毒	向长期记忆或状态存储写入恶意规则
T03	远程载荷下载执行	从不可信源下载并执行恶意脚本、二进制或配置
T04	内嵌恶意代码	Skill 包内包含凭据窃取、破坏性命令或隐蔽外传脚本
T05	越权访问与提权	诱导 Agent 获取超出任务所需的权限
T06	系统持久化驻留	利用服务、启动项或自启机制留下后门
T07	工具劫持与伪装	篡改或伪造本地工具、API 调用路径或 Tool Schema
T08	不安全依赖	通过依赖混淆、typosquatting 或恶意包污染环境
T09	不安全编码	非恶意但真实可利用的安全缺陷，如硬编码密钥或命令注入

此外，评估 Skill 本身的安全可信度，绝非简单的“非黑即白”恶意检测，我们在风险类别中特意引入了“ T09 不安全编码行为”。

我们发现在真实的 Agent 生态中，大量由正常工程人员开发的 Skill 主观上并无恶意，但由于缺乏安全编码规范，其代码中往往伴随着硬编码凭证、敏感权限过度声明、缺乏输入校验等不可信缺陷。这些缺陷如同软件供应链中的潜伏漏洞：即使开发者主观无害，其不安全的代码仍可能被黑客通过提示词注入或间接指令劫持，成为入侵系统的隐性通道。

04 首期评测发现：高召回不等于可落地

SkillTrustBench 首期评测包含两组核心榜单：一组比较不同扫描工具，一组比较同一扫描流程在不同底层模型上的表现。

首期横评对比了当前开源生态中关注度较高的几款开源 Skill 开源扫描方案：

1. Skill Vetter **(OpenClaw / Hermes Agent)**：当前下载量最高的安全审计 Skill，可以快速部署在各类 Agent 框架中，在 Skill 安装前检查风险并在对话中提示用户。(https://clawhub.ai/spclaudehome/skill-vetter)
2. Cisco Skill Scanner：Cisco AI Defense 开源的检测工具，结合了静态规则、LLM 语义分析与行为数据流分析，重点扫描提示注入、数据泄露及恶意代码。(https://github.com/cisco-ai-defense/skill-scanner)
3. NVIDIA SkillSpector：采用两阶段检测架构。第一阶段利用 AST 行为分析、依赖项校验、污点追踪及 YARA 规则进行快速初筛；第二阶段引入 LLM 进行上下文语义分析，用以过滤误报并输出解释。(https://github.com/NVIDIA/skillspector)

在扫描器横评中，统一使用 DeepSeek v4 Flash 作为底座模型。最新公开结果如下：



在最新榜单中，**Skill Vetter + OpenClaw** 的组合召回率与综合分值（F1） 最高；**Skill Vetter + Hermes Agent** 组合综合排名第二，但误报最少。**Cisco Skill Scanner**的召回率不错，但误报率达到24%。NVIDIA SkillSpector 的误报较少，但漏报最多。

这组数据说明，安全检测不能只单看召回率或误报率。在真实 Skill 市场上架前审计、企业内部 CI/CD 流程和 Agent 平台里，高误报会直接损害 Skill 的可用性。一个扫描方案 如果把大量正常 Skill 标成恶意，最终结果往往不一定是更安全，而是被用户选择忽略提示。能抓住恶意样本是第一步。能放过正常样本，才是进入生产流程的前提。

在模型底座评测中，SkillTrustBench 固定扫描器配置，仅替换底层推理模型，观察不同模型在以 A.I.G 最新内测版作为 Skill 安全扫描工具时的表现：

- **能力最强之选 Claude Opus 4.6 与 GLM-5.1** 。两者在风险推断、指令关联分析和意图识别方面表现出较好的均衡性，综合分值最高；不过相比之下，GLM 5.1的评测 Token 成本相对更低（不到 Claude 4.6 Opus 的 10%）。
- 性价比之选 DeepSeek-V4-Flash 与 Hy3 Preview。整体表现相对均衡，误报控制较好，适合作为低成本的安全评测参照基线。适合在 Skill 市场上架前扫描这种任务较高的场景中落地使用。
- **偏向性特征表现：**
  - **Gemini 3.5 Flash** 在本组评测中展现出较高的精确率与极低的误报率，但在复杂样本的召回能力上相对保守，会有部分漏报。
  - **GPT-5.5** 表现出较高的召回率，但其误报率高达18.67%，在安全性研判上更偏向于宁可误报、也不漏过的风格。

对于模型厂商而言，SkillTrustBench 不仅测试了模型的语义理解，还考验其对代码逻辑、多步指令的链式推理和敏感边界的划定能力。过去，这种垂类安全任务场景的能力比较一直缺少足够全面权威的标尺，SkillTrustBench 旨在为大模型在此类安全任务类推理提供一个客观的评估基准。

05 共建安全可信的 Agent Skills 生态

当前，Agent Skill 安全扫描的核心问题已从有没有工具，迈向如何证明有效的新阶段。由于 Skill 兼具代码与自然语言的双重属性，且攻防对抗动态演进，行业长期缺乏统一标尺，导致各方的评估结果各说各话，企业难以选择合适的扫描方案。

我们希望 SkillTrustBench 的发布能够为行业提供 AI 技能安全检测的客观评估基准，推动检测能力从定性走向定量。作为一项持续演进的项目，我们将紧跟最新的攻防实践，不断充实评测集，也诚挚邀请各方加入共建：

- **大模型厂商：**提交新模型评测结果，评估模型在 Agent Skill 安全审查场景中的能力水位；
- **Agent 平台与 Skill 市场：**评估并优化内置的安装前安全审计方案；
- **安全扫描工具：**提交新版本扫描方案，横向比较检测能力演进；
- **安全研究者：**提交真实攻击样本、绕过案例和良性高风险样本，共同完善 benchmark 覆盖面。

联系与合作：zhuque@tencent.com

参考资料

- 腾讯朱雀实验室：我们扫描了五万个 Skill，发现危险仍然存在
- Snyk：ToxicSkills: Agent Skills supply chain compromise study(https://snyk.io/blog/toxicskills-malicious-ai-agent-skills-clawhub/)
- SkillProbe：Security Auditing for Emerging Agent Skill Marketplaces via Multi-Agent Collaboration(https://arxiv.org/abs/2603.21019)
- Trail of Bits：The sorry state of skill distribution(https://blog.trailofbits.com/2026/06/03/the-sorry-state-of-skill-distribution/)
- ClawHub Security Signals：When VirusTotal, Static Analysis, and SkillSpector Disagree(https://huggingface.co/papers/2606.01494)

关于腾讯朱雀实验室

腾讯朱雀实验室（Tencent Zhuque Lab）是腾讯安全平台部于 2019 年成立的顶尖 AI 安全实验室，专注于 AI 安全领域的实战攻防与前沿技术研究，研究方向涵盖大模型安全、AI 智能体安全、AI 赋能安全与 AI 生成检测等领域。团队多次协助英伟达、谷歌、微软等知名厂商以及OpenClaw、Linux、Huggingface等开源社区修复大量高危漏洞，并获得官方公开致谢。先后推出开源 AI 红队安全测试平台 A.I.G（AI-Infra-Guard）及朱雀 AI 检测助手等AI安全产品。研究成果广泛发表于 Black Hat、DEF CON、ICLR、CVPR、NeurIPS、ACL 等国际顶级安全与 AI 学术会议，并出版专著《AI 安全：技术与实战》。



腾讯技术工程
腾讯技术官方号。腾讯技术创新、前沿领域发布解读平台。
688篇原创内容
公众号



阅读 3360

留言

写留言

还没有留言，来写首评